



Higher-ed edtech audit scorecard: 1EdTech TrustEd Apps rubrics, LTI 1.3 interoperability, HECVAT, and EDUCAUSE 2026 standards in one matrix

- Computer
 - Higher-ed feature roadmap & gap analysis: turn 1EdTech, HECVAT, and EDUCAUSE 2026 audit findings into an engineering sprint plan
- Computer
 - Build an app security evidence register
 - Map our features to HECVAT controls
 - Draft a higher-ed data retention policy

Below is a practical way to build Semester’s audit scorecard, security evidence register, HECVAT mapping, engineering sprint plan, and data-retention policy. The important distinction is that **HECVAT is a higher-ed vendor questionnaire, not a certification**, while 1EdTech TrustEd Apps rubrics and interoperability certifications have their own review processes. [¹⁶⁷⁶]^[1]

Unified audit scorecard

Use one control register, then map each control to multiple frameworks rather than maintaining separate spreadsheets for HECVAT, 1EdTech, AI, accessibility, and internal engineering.

Score scale

Score	Meaning	Release implication
0	Missing, unknown, or contradicted by implementation	Block high-risk launch/use
1	Policy or design exists, but implementation/evidence is incomplete	Remediation required before customer claim
2	Implemented, but manually operated or inconsistently tested	Time-bound remediation plan
3	Implemented, owned, monitored, and evidenced	Customer-review ready
4	Independently tested, continuously improved, and transparently reported	Benchmark-level control

Framework matrix

Control domain	HECVAT focus	1EdTech / TrustEd Apps focus	EDUCAUSE 2026 alignment	Semester evidence
Governance	Risk management, policies, roles, audit readiness	Public policy availability and accountable practice	Collaborative cybersecurity and institutional connection	Governance charter, RACI, risk register, board/executive reviews
Identity and access	SSO, MFA, least privilege, access reviews, offboarding	Security-practice review	Shared security responsibility	IAM architecture, MFA evidence, quarterly access-review record

Control domain	HECVAT focus	1EdTech / TrustEd Apps focus	EDUCAUSE 2026 alignment	Semester evidence
Data inventory	Classification, storage, privacy, lifecycle	Data collected, ownership, purpose, retention	Data foundation and governance	Data map, RoPA/data inventory, classification policy
Retention and deletion	Retention, disposal, backups, legal holds	Clear deletion/retention policy and process	Trust and responsible data use	Retention schedule, deletion test, legal-hold runbook
FERPA and privacy	Contractual/privacy control evidence	Ownership, collection, sharing, policy clarity	Student trust and digital access	DPA, privacy policy, consent/disclosure logs, access matrix
AI governance	AI/vendor controls, data processing, change control	Gen-AI data transparency, opt-in/out, source and provider disclosure	AI literacy, responsible adoption, shared governance	AI inventory, evaluation reports, provider assessments, AI policy
Application security	Secure SDLC, vulnerability management, penetration tests	Cybersecurity practices	Collaborative cybersecurity	SDLC evidence, SAST/DAST, dependency scans, pentest summary
Availability/resilience	Backup, disaster recovery, incident response, business continuity	Security/service reliability evidence	Resilient digital services	RTO/RPO, restore tests, incident/tabletop reports
Accessibility	IT accessibility, procurement, conformance evidence	Accessibility rubric, ACR/VPAT, alternatives/accommodations	Equitable connected student experience	WCAG evidence, ACR/VPAT, issue tracker, manual test records
Interoperability	Secure integration and API controls	LTI, OneRoster, QTI, standards/certification evidence	Connected ecosystem and data foundations	Conformance tests, API docs, integration data maps, sandbox results
Social/community	Data sharing, moderation, safety, role access	Social-interaction policy disclosure	Trust, belonging, responsible community tools	Community policy, moderation runbooks, report/appeal records
Supplier management	Subprocessors, due diligence, contractual controls	Third-party data/AI disclosure	Shared risk management	Vendor inventory, DPAs, annual reviews, change notices

1EdTech’s Data Privacy Rubric specifically examines data collected, data ownership, deletion rights, retention, policy availability, data handling, and social interactions. Its Generative AI Data Rubric adds expectations for AI-use notices, opt-in/out, source identification, internal-versus-third-party disclosure, bias considerations, and data ownership. ^[1425][1681]

Security evidence register

Create this as a controlled system—ideally a GRC module or a secure evidence repository—not a static folder.

Register schema

```

Evidence ID
Control ID
Control name
Framework mappings
Risk addressed
Control owner
System/process in scope

```

Control frequency
Evidence description
Evidence type
Evidence collection method
Evidence location
Evidence date
Review/expiry date
Reviewer
Result/status
Exception ID
Remediation owner
Remediation target date
Customer visibility
Sensitivity classification
Hash/checksum, where useful

Initial evidence register

Evidence ID	Control	Framework mapping	Evidence	Frequency	Owner	Customer visibility
SEC-IAM-001	Privileged-access review	HECVAT IAM; TrustEd security	Export of privileged roles, reviewer sign-off, removal tickets	Quarterly	Security	Under NDA
SEC-IAM-002	MFA enforcement	HECVAT IAM	IdP policy/configuration screenshots or config export; test evidence	Quarterly/change	Security	Summary
SEC-SDLC-001	Secure code review	HECVAT app security	Branch-protection config, PR audit sample, CI policy	Continuous/quarterly sample	Engineering	Summary
SEC-SDLC-002	Dependency and secrets scanning	HECVAT app security	CI scan history, critical-remediation tickets, exceptions	Continuous/monthly review	Engineering	Under NDA
SEC-VULN-001	Vulnerability management	HECVAT vulnerability management	Scan report, severity SLA dashboard, remediation evidence	Continuous/monthly	Security	Executive summary
SEC-PENT-001	Independent penetration testing	HECVAT application/network security	Scope, executive summary, remediation tracker	Annual/major change	Security	Under NDA
SEC-DATA-001	Data inventory and classification	HECVAT privacy/data governance; 1EdTech privacy	Data map, owners, purpose, classification, storage, retention	Quarterly/change	Privacy	Summary
SEC-DATA-002	Deletion and retention enforcement	HECVAT privacy; 1EdTech retention	Deletion job logs, sample test evidence, backup-expiry validation	Quarterly	Privacy/Engineering	Summary
SEC-BCP-001	Backup restoration	HECVAT BCP/DR	Restore exercise results, RTO/RPO measured values, exceptions	Quarterly	Engineering	Under NDA
SEC-IR-001	Incident response	HECVAT incident response	Runbook, tabletop attendance, after-action corrective plan	Annual/major change	Security	Summary

Evidence ID	Control	Framework mapping	Evidence	Frequency	Owner	Customer visibility
SEC-LOG-001	Audit logging	HECVAT logging/monitoring	Log architecture, sample audit events, retention/config evidence	Quarterly	Engineering/Security	Under NDA
SEC-VEND-001	Subprocessor review	HECVAT third-party risk; 1EdTech privacy	Vendor inventory, DPA, security review, renewal/change review	Before use/annual	Privacy	Public list + NDA detail
SEC-AI-001	AI provider/data-use review	1EdTech AI rubric; HECVAT vendor/privacy	Model inventory, provider terms, retention/training review, approval	Before enablement/annual	AI/Privacy	Summary
SEC-AI-002	AI evaluation and misuse testing	AI governance; secure SDLC	Evaluation plan, red-team report, sign-off, issue tracker	Per model/change	AI/Engineering	Summary
ACC-001	Accessibility release gate	HECVAT accessibility; 1EdTech accessibility	Automated/manual test results, known issues, remediation decision	Per release	Accessibility	ACR/VPAT summary
INT-001	LTI integration validation	1EdTech interoperability; HECVAT integration	Launch/AGS/NRPS test logs, data map, customer sign-off	Per tenant/change	Integrations	Summary
PRIV-001	FERPA disclosure/consent audit	HECVAT privacy; 1EdTech privacy	Consent record, disclosure log, recipient/purpose/scope, revocation test	Continuous/quarterly review	Privacy	Under NDA

Map features to HECVAT

Do not map features only at a marketing level. Map each feature to its data, risks, controls, and supporting evidence.

Semester feature	Primary data/risk	HECVAT control themes	Required controls	Evidence
Student account and SSO	Identity, authentication, account takeover	IAM, authentication, access control	SSO/OIDC/SAML, MFA for privileged roles, session controls, account recovery	IAM diagram, MFA config, access-review evidence
Personal Academic OS	Plans, tasks, calendar, personal notes	Privacy, data classification, application security	Private-by-default, tenant isolation, export/delete, audit, backup	Data map, privacy UX tests, authorization tests
Native LMS/course workspace	Course content, enrollment, submissions	Application security, privacy, integrations, accessibility	Role-based course access, rights controls, LTI/OneRoster validation, secure file handling	Threat model, integration tests, content-access logs
Study Studio/AI	Prompts, course sources, generated content	AI, vendor management, privacy, security	Tenant-scoped retrieval, no general-model training by default, safety filters, provider review	AI inventory, evaluation report, provider DPA
Assessment and gradebook	Grades, assessment responses, feedback	Privacy, integrity, audit, availability	Grade ledger, authorized graders, release controls, backup/recovery, no AI-only final grade	Grade change logs, calculation test suite, restore test
Club/community module	Social data, harassment, moderation evidence	Privacy, social interactions, access, incident response	Role scope, block/report, moderation workflow, retention, appeal	Policy, case-audit sample, role matrix

Semester feature	Primary data/risk	HECVAT control themes	Required controls	Evidence
Peer mentorship	Private communications, sensitive context	Privacy, access control, safety	Opt-in, boundaries, limited coordinator view, escalation, data minimization	Consent flow, training record, access test
Basic-needs navigator	Highly sensitive help-seeking data	Privacy, data minimization, incident response	Private browsing, named referral, consented sharing, restricted case access	Resource policy, consent logs, authorization tests
Career/opportunity network	Portfolio, employer visibility, opportunity data	Privacy, third parties, access control	Student opt-in, artifact-level sharing, no academic-data sale, expiry/revoke	Sharing logs, employer terms, access audit
Operations Console	Production data, privileged actions	IAM, logging, change management, security	Least privilege, time-bound support access, approval, audit, break-glass review	Console access logs, approvals, access reviews
Integrations gateway	External credentials, roster/grade data	Third-party risk, encryption, APIs, monitoring	Secret vault, scoped OAuth, rate-limit handling, retry/reconciliation, tenant segregation	Data-flow map, secret policy, sync logs
Payments	Financial/transaction data	Payment security, vendor risk, logging	Use compliant processor/tokenization, minimize card data, reconciliation	Processor attestation, architecture diagram, access controls

Engineering sprint plan

Convert audit findings into work that is shippable, measurable, and auditable.

Prioritization rule

P0:

Security, privacy, data-loss, critical accessibility, grade integrity, or misleading AI/official-information risk.

P1:

Blocks procurement, integration, adoption, support, or core student value.

P2:

Important quality, automation, or scalability improvement.

P3:

Enhancement, polish, or future differentiation.

First 12 sprints

Sprint	Engineering objective	Evidence output	Customer value
1	Tenant isolation and shared identity foundation	Authorization test suite, tenant-bound audit events	Safe multi-institution foundation
2	Data inventory and classification service	Data map and field-classification registry	Clear privacy/procurement answers
3	Consent/share/revoke engine	Consent/disclosure logs and revocation tests	Student data agency
4	Central audit log and evidence service	Immutable audit-event schema and access logs	Traceable operations
5	Secrets, CI security, SDLC gates	Scan reports, branch protection, deployment evidence	Security baseline

Sprint	Engineering objective	Evidence output	Customer value
6	Backup, restore, and incident readiness	Restore test, RTO/RPO record, incident tabletop	Reliability confidence
7	Accessibility design-system and release gate	Component test suite, accessibility backlog	Inclusive experience and ACR foundation
8	AI policy and provider-control plane	AI inventory, policy decisions, provider review	Governed AI posture
9	Source/Scope/Status metadata service	Trust-payload API and user-facing component evidence	Honest, understandable product
10	LTI/OneRoster integration gateway and sandbox	Conformance test logs, integration data maps	Interoperability readiness
11	Gradebook ledger and assessment audit controls	Grade calculation tests, release/change audit	Trustworthy grading
12	Procurement room and evidence export	HECVAT response library, customer trust dashboard	Faster enterprise evaluation

Audit-to-sprint workflow

```

Audit finding
→ map to risk and framework controls
→ identify product/control owner
→ define measurable acceptance criteria
→ create engineering story and evidence deliverable
→ implement and test
→ security/privacy/accessibility review
→ store evidence
→ update control status
→ validate in staging/production
→ update customer-facing claim only after evidence exists

```

Draft higher-ed data retention policy

This is a framework draft. Final dates and legal language must be reviewed with counsel and configured per customer agreement, institutional records schedules, applicable law, litigation/legal holds, and operational needs.

FERPA itself does not prescribe a general record-retention schedule; institutions still have duties under other laws, contracts, institutional schedules, and preservation obligations. Therefore, Semester should not claim a universal FERPA retention period. ^[1680]_[1684]

Semester Data Retention, Deletion, and Preservation Policy

1. Purpose

Semester retains information only for the period necessary to provide the service, maintain security and reliability, meet contractual and legal obligations, support approved institutional records requirements, resolve disputes, and protect the rights of users, customers, and Semester.

This policy establishes default retention principles. Customer agreements, institution-specific configurations, applicable law, approved records schedules, and valid legal holds may require different retention periods.

2. Guiding principles

Purpose limitation
Data minimization
Tenant-specific configuration
Student and customer data agency
Secure deletion
Backup lifecycle management
Preservation for valid legal holds
Access restriction during retention
Documented exceptions
Transparent communication

3. Data classes

Data class	Examples	Default retention approach
Account and identity	Name, email, SSO identifiers, authentication records	Active account period plus a defined post-termination/security period; delete/anonymize unless retention is required
Student private workspace	Personal plans, tasks, notes, preferences, eligible AI history	Retain while account/tenant feature is active; honor eligible deletion/termination configuration; preserve only under valid hold/requirement
Course content	Instructor materials, source documents, syllabus data	Customer-controlled term/course lifecycle plus configured archive period; rights and institutional policy apply
Assessment/submission/grade records	Submissions, feedback, grade ledger, audit history	Customer-configured institutional record schedule; do not delete contrary to official academic-record requirements
Community and club content	Profiles, posts, membership, event activity	Active lifecycle plus customer-configured archive/deletion period; retain moderation evidence only as necessary
Support data	Tickets, diagnostic logs, support-access records	Defined support/contract/security period; minimize attachments and sensitive data
Basic-needs/referral metadata	Consent, recipient, status, limited referral record	Minimum necessary period; sensitive intake remains with official service system where possible
AI data	Prompts, outputs, policy decisions, evaluation samples	Minimum period for feature operation, safety, support, and agreed configuration; separate production usage from approved de-identified evaluation
Security/audit logs	Authentication, access, administrative actions, security events	Retain according to security and contractual requirements; access restricted and monitored
Integration data	Sync state, external IDs, error records, reconciliation logs	Active connection plus defined troubleshooting/reconciliation period; remove credentials promptly on disconnect
Billing/contract records	Invoices, contracts, tax and payment records	Retain as required by law, accounting, and contract obligations
Backups	Encrypted point-in-time copies	Short, documented lifecycle; delete through rolling expiration; do not use as primary active-data store

4. Customer configuration

Each institutional customer may configure or approve retention periods for eligible data classes, subject to:

Applicable law and regulation
Institutional records schedules
Academic-record preservation obligations
Contract terms

- Technical feasibility
- Security requirements
- Valid legal holds
- Protection against accidental or malicious deletion

Semester will document the configured retention profile and make it available to authorized customer administrators.

5. Deletion

When deletion is requested or a retention period expires, Semester will:

- Verify authority and scope.
- Identify active shares, dependencies, and legal holds.
- Delete or de-identify eligible primary data.
- Revoke applicable access and integration tokens.
- Queue deletion of derived indexes, caches, and eligible AI retrieval representations.
- Allow encrypted backups to expire through their documented lifecycle, rather than attempting unsafe selective backup alteration where impracticable.
- Record completion and exceptions in an audit log.
- Provide confirmation to the authorized requester where appropriate.

Deletion does not necessarily remove information that must remain under a valid legal hold, contractual requirement, institutional record schedule, security requirement, or legal obligation.

6. Legal holds and preservation

A valid legal hold overrides ordinary deletion and retention schedules for information within its defined scope.

- Legal hold intake and validation
- Scope definition
- Custodian/system identification
- Deletion-job suspension for in-scope records
- Restricted access
- Preservation audit trail
- Periodic review
- Hold release
- Resumption of ordinary retention/deletion after release

7. AI-specific retention

- Student/institution production content is not used for general-purpose AI training by default.
- AI prompts and outputs are retained only as required for the configured feature, security, safety, support, contract, and approved retention schedule.
- Retrieval indexes, caches, evaluation samples, and provider-held data are included in the data map and deletion process.
- AI provider retention/training settings are documented and contractually reviewed.

8. Security and access

Retained information remains protected through:

- Encryption in transit and at rest
- Role-based access

Least privilege
Time-bound support access
Audit logging
Monitoring and periodic access review
Secure deletion procedures
Vendor/subprocessor controls

9. Transparency and requests

Semester provides applicable users and customers with information about:

Data categories
Retention approach
Available export, correction, deletion, restriction, and revocation controls
Active shares and integrations
Legal-hold limitations
Contact routes for privacy and security questions

10. Review and updates

This policy is reviewed at least annually and after material changes to product functionality, data practices, regulations, subprocessors, AI providers, customer requirements, or security incidents.

Retention implementation matrix

Before publishing concrete durations, create a customer/legal-approved schedule:

Class	Default duration	Customer-configurable?	Hold override?	Backup lifecycle	Owner
Account identity	[define]	Limited	Yes	[define]	Privacy
Student private workspace	[define]	Yes	Yes	[define]	Product/Privacy
Course materials	[define]	Yes	Yes	[define]	Academic customer owner
Grades/submissions	[define]	Yes, within records rules	Yes	[define]	Registrar/academic owner
AI prompts/outputs	[define]	Yes	Yes	[define]	AI/Privacy
Audit/security logs	[define]	Limited	Yes	[define]	Security
Support data	[define]	Limited	Yes	[define]	Support/Privacy
Integration logs	[define]	Limited	Yes	[define]	Integrations
Billing/contract records	[define]	No/limited	Yes	[define]	Finance/Legal

The 1EdTech Data Privacy Rubric explicitly evaluates whether policy language identifies collected data, collection method, data ownership, deletion rights, and retention. Its highest rubric expectations favor clear, specific retention and deletion statements rather than “we retain data as long as necessary” language with no operational detail. [^1425]

Immediate next actions

1. Create the evidence register with the schema above.
2. Complete HECVAT 4 against real evidence; mark gaps honestly.
3. Build a data inventory and retention implementation matrix before publishing duration commitments.
4. Implement the first 12 engineering control sprints, prioritizing P0 security/privacy/accessibility/grade-integrity risks.
5. Complete internal 1EdTech Privacy, Security, Accessibility, and Gen-AI rubric self-assessments with linked evidence.
6. Build the secure procurement room and version every artifact.
7. Run quarterly control reviews, restore tests, access reviews, AI evaluations, and accessibility release reviews.

That system makes compliance a product advantage: Semester becomes easier for universities to evaluate because it can show not just what it promises, but the evidence that the promise is operating.

*
**

1. <https://er.educause.edu/articles/2025/2/hecvat-4-better-than-ever>
2. <https://www.1edtech.org/standards/data-privacy/rubric>
3. <https://www.educause.edu/higher-education-community-vendor-assessment-toolkit>
4. <https://www.1edtech.org/standards/data-privacy>
5. <https://www.1edtech.org/certification/data-privacy/faq>
6. <https://www.1edtech.org/certification/data-privacy>
7. <https://www.1edtech.org/standards/security-practices-rubric>
8. <https://www.upguard.com/blog/hecvat>
9. <https://www.imsglobal.org/spec/privacy/v1p0>
10. <https://build.1edtech.org/standards>
11. <https://studentprivacy.ed.gov/resources?page=14>
12. <https://www.millikin.edu/sites/default/files/2024-04/FERPA Basics - University Employees.pdf>
13. <https://www.1edtech.org/standards/ai-rubric>
14. <https://www.davidsondavie.edu/wp-content/uploads/2026/07/Policy-5.4.3-Student-Records-FERPA-10-14-2025-1.pdf>
15. <https://www.1edtech.org/1edtech-article/new-1edtech-rubrics-provide-valuable-insights-for-educators-selecting-trusted>
16. <http://www.kauai.hawaii.edu/ferpa-faculty>